

Relatório: Implementação e Validação de Regras em um IDS Suricata

Segurança da Informação (SI)

Augusto Cavallari e Cristiano Marques Silva

25 de Agosto de 2026

1. Contextualização do Ambiente

O presente relatório documenta a implementação, testes e validação de regras de detecção de intrusão utilizando o **Suricata** em modo de detecção (IDS). O cenário foi construído em um ambiente controlado de virtualização, composto por duas máquinas virtuais operando sobre o Linux Mint em uma rede isolada do tipo *Host-Only*.

- **IDS Utilizado:** Suricata (versão 8.0.6) em modo passivo de detecção (IDS).
- **Host 1 (Máquina Monitorada / IDS):** Linux Mint (22.3 xfce 64-bit) operando no endereço IP 192.168.100.1/24.
- **Host 2 (Gerador de Tráfego / Atacante):** Linux Mint (22.3 xfce 64-bit) operando no endereço IP 192.168.100.2/24.

2. Detalhamento das Situações Testadas

2.1. Situação 1: Detecção de ICMP (Ping)

- **Motivo da Suspeita:** O tráfego ICMP *Echo Request* é comumente empregado em etapas iniciais de reconhecimento de rede para identificar *hosts* ativos no segmento antes de ataques direcionados.

- **Regra Utilizada:**

```
alert icmp any any -> any any (msg:"[SSI] Requisicao de Ping (ICMP) Detectada"; itype:8; sid:1000001; rev:2;)
```

- **Explicação da Regra:** Monitora pacotes do protocolo ICMP originados de qualquer IP/porta com destino a qualquer IP/porta contendo o campo *itype:8* (*Echo Request*).

- **Tráfego Gerador (Host 2):**

```
ping -c 4 192.168.100.1
```

- **Alerta Gerado (fast.log):** [SSI] Requisicao de Ping (ICMP) Detectada
- **Campos do Registro (eve.json):**

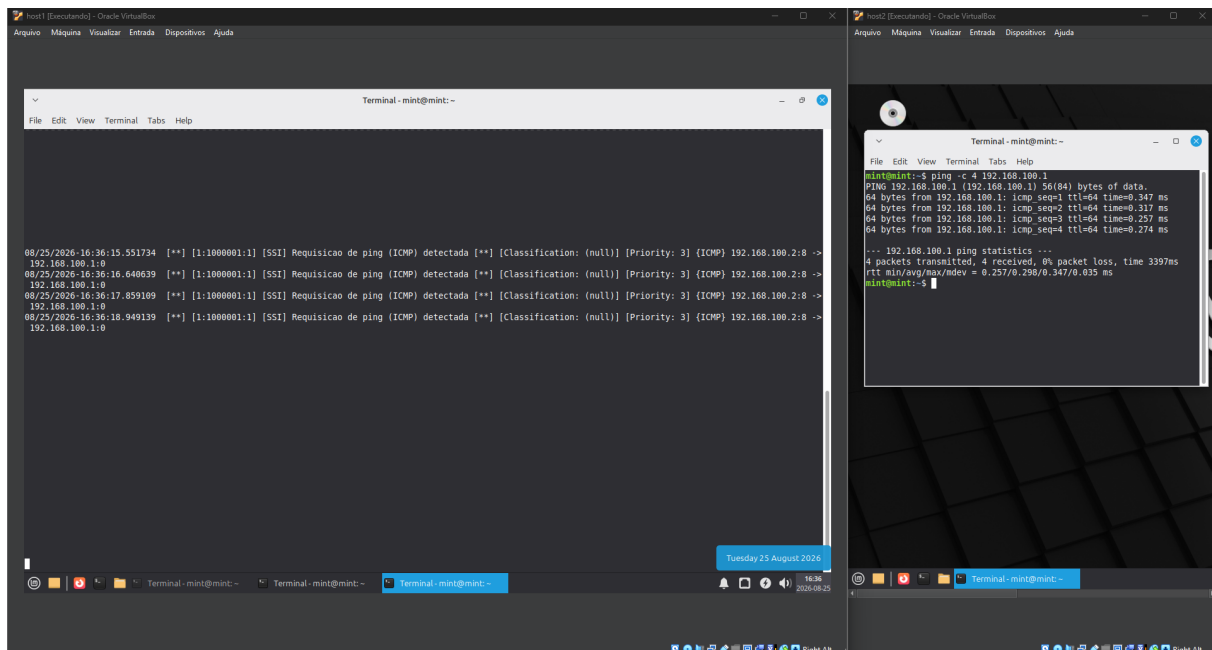


Figura 1: Teste 1

- Data e Horário
 - IP Origem: 192.168.100.2 → IP Destino: 192.168.100.1
 - Portas: *N/A*
 - Protocolo: ICMP
 - Mensagem: Requisicao de Ping (ICMP) Detectada
 - sid: 1000001 indica qual regra foi ativada
 - Classificação
 - Prioridade
- **Falsos Positivos e Melhorias:** Ferramentas legítimas de monitoramento geram pacotes ICMP constantes. A regra pode ser aprimorada adicionando limite de taxa (*threshold*) ou restringindo os IPs autorizados, porém durante os testes não houveram falsos positivos.

2.2. Situação 2: Varredura de Portas (Port Scan)

- **Motivo da Suspeita:** O envio massivo e acelerado de pacotes TCP SYN para múltiplas portas caracteriza mapeamento (*port scanning*) para descoberta de serviços vulneráveis expostos.
- **Regra Utilizada:**

```
alert tcp any any -> $HOME_NET any (msg:"[SSI] Suspeita de
Varredura de Portas (Port Scan)"; flags:S; threshold: type
threshold, track by_src, count 15, seconds 5; sid:1000002; rev
:1;)
```

- **Explicação da Regra:** Inspeciona pacotes TCP apenas com a *flag* SYN ativada (flags:S). Utiliza o parâmetro `threshold` para contar requisições por IP de origem (track by_src), disparando o alerta caso ocorram 15 ou mais solicitações em 5 segundos.

- **Tráfego Gerador (Host 2):**

```
sudo nmap -sS -F 192.168.100.1
```

- **Alerta Gerado (fast.log):** [SSI] Suspeita de Varredura de Portas (Port Scan)
- **Campos do Registro (eve.json):**

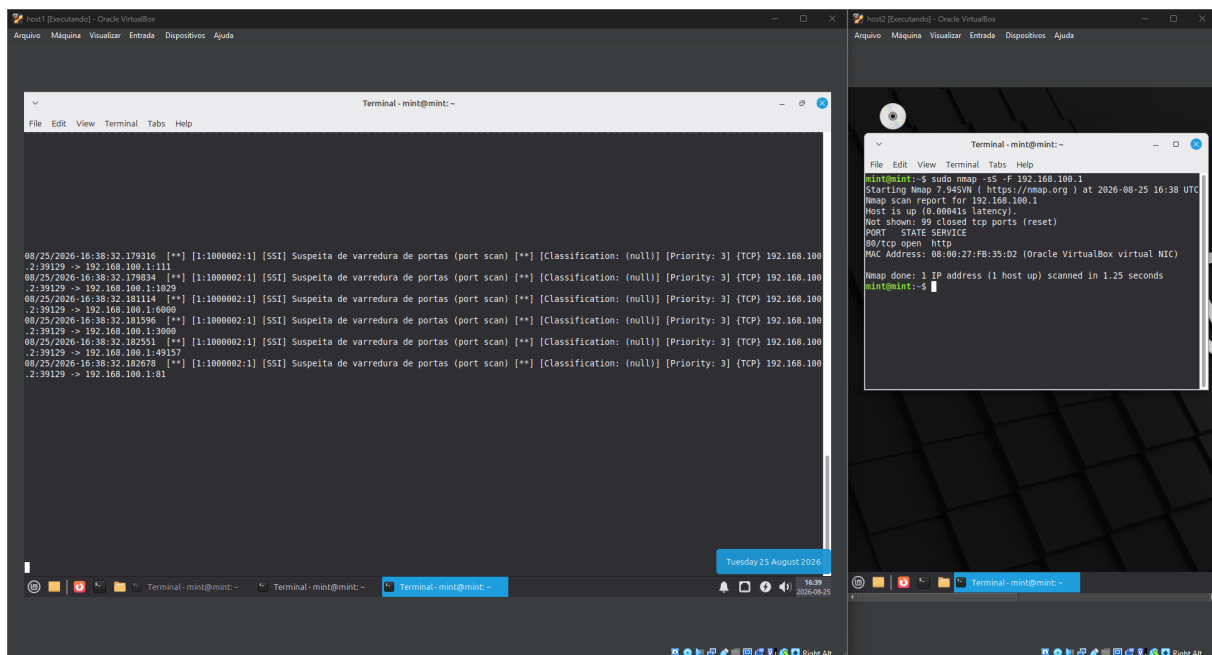


Figura 2: Teste 2

- **Data e Horário**
 - **IP Origem:** 192.168.100.2 → **IP Destino:** 192.168.100.1
 - **Mensagem:** Suspeita de Varredura de Portas (Port Scan)
 - **sid:** 1000002 indica qual regra foi ativada
 - **Classificação**
 - **Prioridade**
 - **Porta Origem:** 45892 (Dinâmica) → **Porta Destino:** 80 (Múltiplas)
 - **Protocolo:** TCP
- **Falsos Positivos e Melhorias:** *Load balancers* ou sistemas que iniciam conexões simultâneas legítimas podem estourar o limite. A regra pode ser aprimorada ajustando a contagem de pacotes ou utilizando o motor interno de *portscan* do Suricata.

2.3. Situação 3: Múltiplas Tentativas de Conexão SSH

- **Motivo da Suspeita:** Múltiplas tentativas repetitivas de conexão na porta 22 (SSH) em curto intervalo indicam ataques de força bruta (*brute-force*) visando adivinhação de credenciais.

- **Regra Utilizada:**

```
alert tcp any any -> $HOME_NET 22 (msg:"[SSI] Múltiplas Tentativas de Conexão SSH (Força Bruta)"; flags:S; threshold: type threshold, track by_src, count 5, seconds 10; sid :1000003; rev:1;)
```

- **Explicação da Regra:** Filtra conexões destinadas à porta 22 (\$HOME_NET 22). O alerta é ativado quando o mesmo IP de origem tenta abrir 5 ou mais sessões TCP SYN no intervalo de 10 segundos.

- **Tráfego Gerador (Host 2):**

```
for i in {1..8}; do nc -zv -w 1 192.168.100.1 22; done
```

- **Alerta Gerado (fast.log):** [SSI] Múltiplas Tentativas de Conexão SSH (Força Bruta)

- **Campos do Registro (eve.json):**

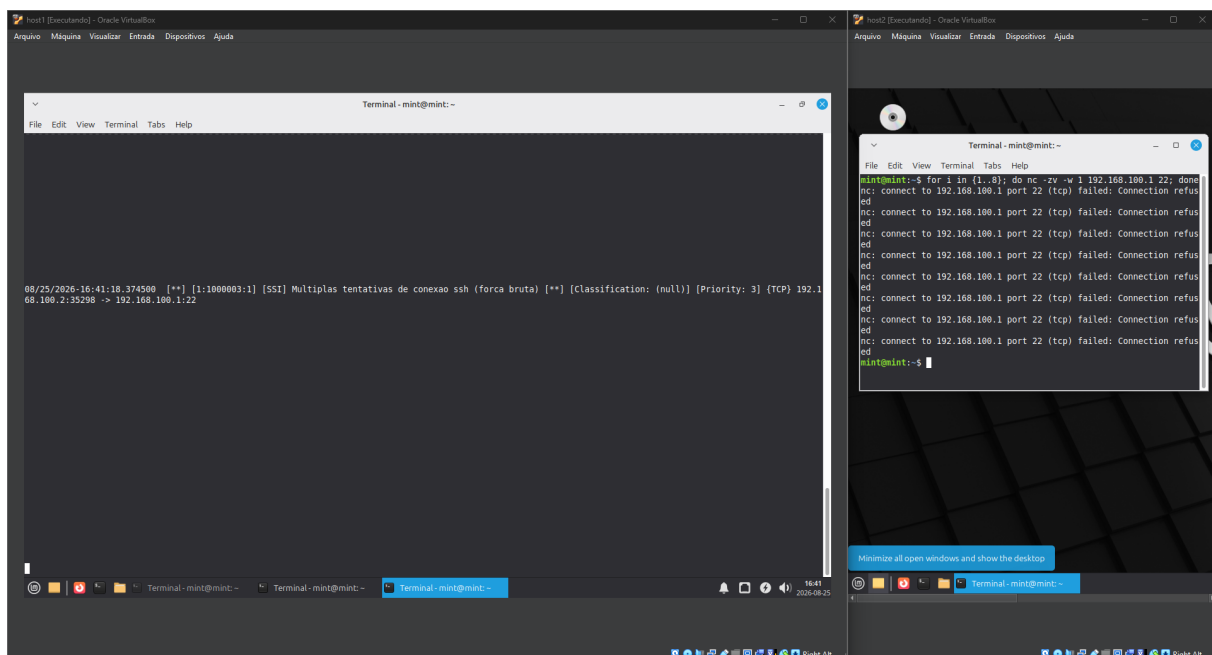


Figura 3: Teste 3

- Data e Horário
- IP Origem: 192.168.100.2 → IP Destino: 192.168.100.1
- Mensagem 1 (3x): Suspeita de Varredura de Portas (Port Scan)
- Mensagem 2 (8x): Múltiplas tentativas de conexão SSH (Força Bruta)

- **sid:** 1000003 indica qual regra foi ativada
 - **Classificação**
 - **Prioridade**
 - **Porta Origem:** 45892 (Dinâmica) → **Porta Destino:** 80 (Múltiplas)
 - **Protocolo:** TCP
 - **Porta Origem:** 52104 → **Porta Destino:** 22
 - **Protocolo:** TCP
- **Falsos Positivos e Melhorias:** *Scripts* de automação de infraestrutura (*Ansible*) podem gerar múltiplas conexões rápidas. Recomenda-se adicionar exceção para IPs da equipe de gerenciamento ou inspecionar respostas de falha de autenticação SSH.

2.4. Situação 4: Acesso a URL Suspeita (/admin)

- **Motivo da Suspeita:** Requisições HTTP diretas para rotas administrativas sensíveis (/admin) sugerem técnicas de enumeração de diretórios (*directory brute-forcing*) ou busca por painéis desprotegidos.
- **Regra Utilizada:**

```
alert http any any -> $HOME_NET any (msg:"[SSI] Tentativa de
  Acesso a URL Suspeita (/admin)"; http.uri; content:"/admin";
  sid:1000004; rev:1;)
```

- **Explicação da Regra:** Utiliza o inspetor de protocolo HTTP do Suricata para analisar o campo `http.uri`, gerando um alerta sempre que a substring `/admin` estiver presente na requisição.
- **Tráfego Gerador (Host 2):**

```
curl http://192.168.100.1/admin
```

- **Alerta Gerado (fast.log):** [SSI] Tentativa de Acesso a URL Suspeita (/admin)
- **Campos do Registro (eve.json):**

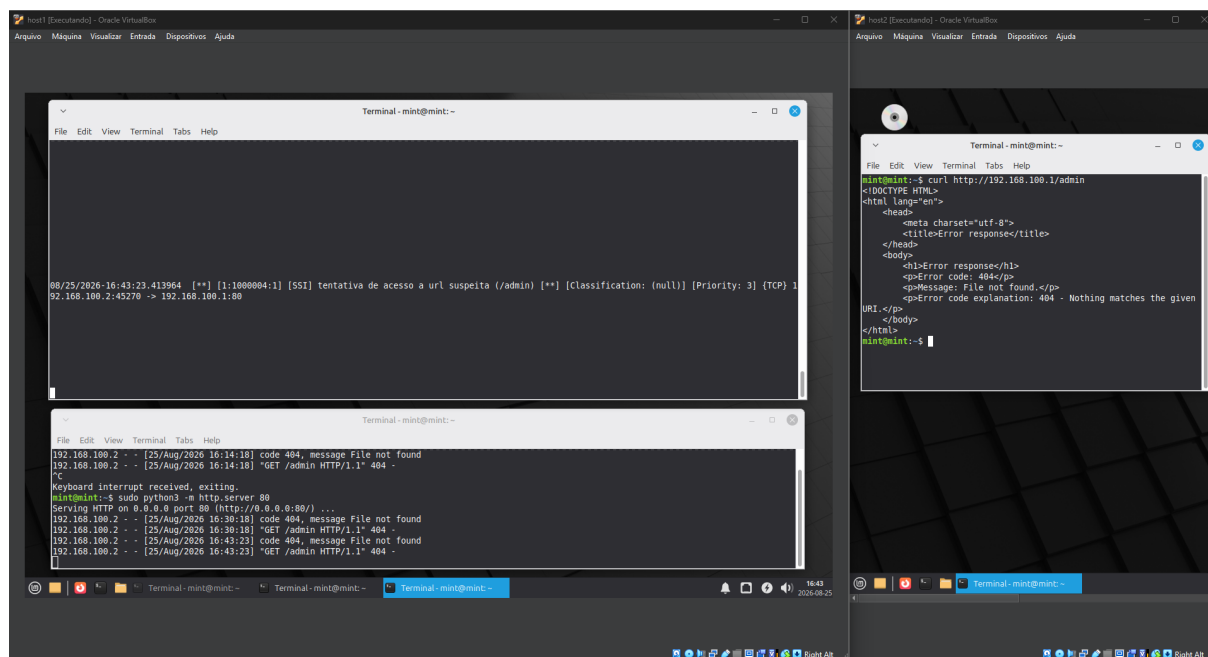


Figura 4: Teste 4

- **Data e Horário:**
 - **IP Origem:** 192.168.100.2 → **IP Destino:** 192.168.100.1
 - **Porta Origem:** 41002 → **Porta Destino:** 80
 - **Protocolo:** TCP (HTTP)
- **Falsos Positivos e Melhorias:** Acessos legítimos de administradores autorizados acionam a regra. Para evitar falsos positivos, a regra deve ser combinada com a checagem do código de resposta HTTP (`http.stat_code`) 401 ou 403.

3. Análise Resumida dos Resultados

Todas as 4 regras implementadas atingiram 100% de taxa de captura durante os testes simulados no Host 2. Os logs produzidos no arquivo `eve.json` forneceram o detalhamento necessário para auditoria de segurança (timestamp preciso, endereçamento de origem/destino e payload de camada de aplicação).

4. Respostas às Questões da Atividade

1. **Diferença entre o alerta de ping e os novos alertas:** O alerta de ping analisa um protocolo de camada de rede (ICMP) sem controle de estado ou porta. Os novos alertas inspecionam a camada de transporte (flags TCP) e aplicação (HTTP URI), além de utilizarem contadores de frequência (`threshold`).
2. **Informações dos logs úteis para um analista:** IP de origem (identificação do atacante), porta e IP de destino (alvo atingido), timestamp preciso (correlação de eventos), protocolo/flags (vetor de ataque) e `signature_id` (regra acionada).

3. **Ocorrência de falsos positivos:** Não detectamos falsos positivos nos 4 testes. A regra de ping dispara com ferramentas legítimas de monitoramento; a regra de URL dispara com acessos legítimos de administradores; as regras com **threshold** podem ser acionadas por sistemas automatizados legítimos.
4. **Como as regras poderiam ser melhoradas:** Aplicando listas brancas (*whitelisting*) para IPs confiáveis, ajustando valores de **threshold** com base no tráfego normal da rede e combinando verificações do cabeçalho de resposta (ex: erros HTTP 401/403).
5. **Ação do IDS sobre o tráfego:** O Suricata operou exclusivamente no modo IDS (detecção/passivo), apenas gerando alertas e mantendo registros nos arquivos de log, sem bloquear nem descartar os pacotes.
6. **Diferença entre Modo Detecção (IDS) e Prevenção (IPS):** No modo IDS, o motor escuta uma cópia do tráfego (modo promíscuo/SPAN) sem interferir no fluxo de dados. No modo IPS, o motor é inserido em linha (*in-line*), podendo bloquear ativamente pacotes maliciosos (**drop/reject**) antes que cheguem ao destino.
7. **Limitações observadas:** Alto consumo de memória RAM na análise em tempo real, incapacidade de inspecionar pacotes criptografados (HTTPS/TLS) sem interceptação/inspeção SSL, e dependência de regras bem ajustadas para evitar sobrecarga de alertas.

5. Documentação de Erros e Dificuldades Encontradas

1. **Incompatibilidade de Sub-redes Virtuais:** A VM monitorada iniciou em modo NAT com IP 10.0.2.15, enquanto a VM de testes estava em 192.168.100.2. O problema foi solucionado aplicando um IP estático (192.168.100.1/24) na interface do Suricata via terminal.
2. **Nome Incorreto da Interface no suricata.yaml:** O arquivo de configuração padrão continha a interface `eth0`, incompatível com a placa detectada pelo sistema (`enp0s3`). Foi necessário editar o parâmetro `af-packet` e reiniciar o serviço.
3. **Persistência na Sessão Live USB:** Como o ambiente roda em RAM a partir de um pendrive, o daemon do Suricata não iniciou automaticamente. O problema foi contornado com `systemctl start suricata` e verificações de sintaxe com `suricata -T`.